

PROGETTO M5 – SECURITY OPERATION

Analisi e progettazione della sicurezza di una piattaforma e-commerce

Introduzione

L'infrastruttura analizzata riguarda una piattaforma e-commerce accessibile pubblicamente tramite Internet. L'applicazione è collocata in una DMZ (zona demilitarizzata), mentre la rete interna ospita sistemi più critici come database, eventuali servizi di gestione e postazioni aziendali.

Nello scenario iniziale, la DMZ può comunicare con la rete interna tramite policy firewall già configurate. Questa scelta può sembrare necessaria per garantire il funzionamento dell'applicazione, ma introduce un rischio importante: se il server esposto venisse compromesso, un attaccante potrebbe tentare di muoversi lateralmente verso i sistemi interni, aumentando in modo significativo l'impatto dell'attacco.

L'obiettivo di questo progetto è analizzare le principali minacce in questo contesto, proporre misure preventive contro attacchi applicativi (SQL Injection e XSS), valutare l'impatto economico di un attacco DDoS, definire una strategia di response in caso di infezione malware e proporre una modifica più aggressiva dell'infrastruttura, compatibile con un budget massimo di 30–40 mila euro.

1) Azioni preventive contro SQL Injection e XSS

Le vulnerabilità SQL Injection e Cross Site Scripting rientrano tra le minacce più comuni per applicazioni web esposte su Internet. In un contesto e-commerce il loro sfruttamento può portare a:

- accesso non autorizzato al database,
- esfiltrazione di dati sensibili,
- compromissione delle sessioni utente,
- manipolazione di contenuti o transazioni.

La prevenzione efficace non può basarsi su una singola misura, ma su un approccio multilivello.

1.1 Protezione a livello di front-end

La prima misura consiste nell'introduzione di un Web Application Firewall (WAF) posizionato davanti all'applicazione.

Il WAF opera a livello 7 del modello OSI, analizzando il traffico HTTP/HTTPS e bloccando pattern noti associati a SQL injection, XSS e attacchi automatizzati.

Questo consente di:

- ridurre il traffico malevolo prima che raggiunga l'applicazione,
- limitare tentativi di exploit su vulnerabilità note,
- aumentare la visibilità sugli attacchi in corso.

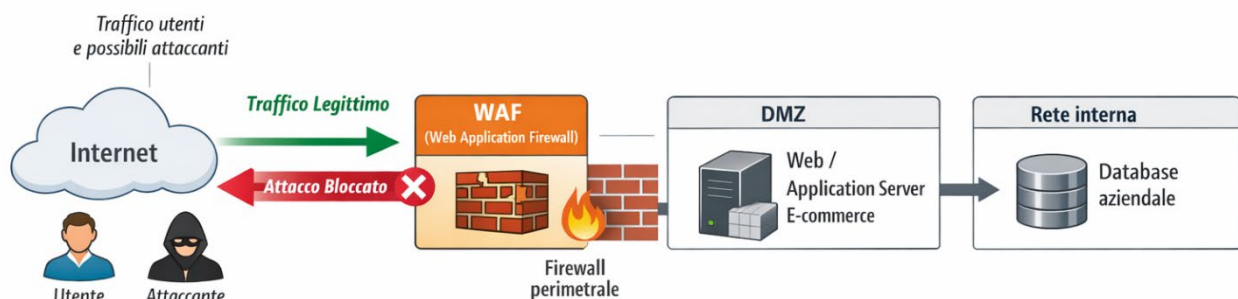


Figura 1 – Architettura di base con WAF a protezione dell'applicazione e-commerce.

Il traffico proveniente da Internet viene filtrato dal WAF e dal firewall prima di raggiungere la DMZ. La rete interna risulta raggiungibile dall'applicazione, rappresentando un potenziale punto di rischio in caso di compromissione del server esposto.

Figura 1 – Architettura di base con WAF a protezione dell'applicazione e-commerce. Il traffico proveniente da Internet viene filtrato dal WAF e dal firewall prima di raggiungere la DMZ. La rete interna risulta raggiungibile dall'applicazione, rappresentando un potenziale punto di rischio in caso di compromissione del server esposto.

1.2 Hardening applicativo

Il WAF è un filtro, ma non sostituisce la sicurezza del codice.

Per mitigare SQL Injection è necessario:

- utilizzare query parametrizzate (prepared statements),
- evitare concatenazioni dirette nelle query SQL,
- applicare il principio del minimo privilegio all'account DB usato dall'applicazione.

Per mitigare XSS è fondamentale:

- validare e sanitizzare tutti gli input utente,
- applicare encoding dell'output,
- configurare header di sicurezza come Content Security Policy,
- impostare cookie di sessione con flag HttpOnly e Secure.

In questo modo, anche se una richiesta malevola dovesse superare il WAF, l'applicazione non dovrebbe essere facilmente sfruttabile.

1.3 Segmentazione tra livelli

Un errore frequente è considerare la DMZ come “sicura di default”. In realtà la DMZ è solo un'area di contenimento.

Il database non deve essere esposto nella DMZ. Deve risiedere nella rete interna ed essere raggiungibile esclusivamente dall'applicazione server tramite porte specifiche.

La logica è semplice:

anche se il web server viene compromesso, l'attaccante non deve avere accesso libero alla rete interna.

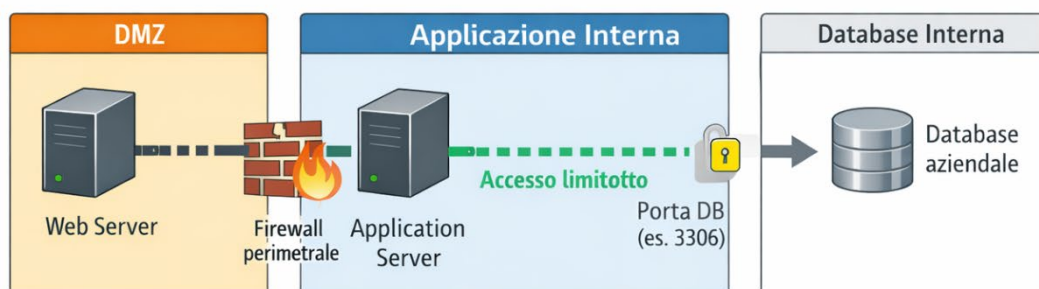


Figura 2 – Segmentazione tra server web, application e database con accesso limitato.

Il database aziendale si trova nella rete interna e non è direttamente accessibile dalla DMZ. È raggiungibile esclusivamente dal server applicativo tramite porte specifiche.

Figura 2 – Separazione logica tra DMZ, livello applicativo e database interno. La segmentazione dell'infrastruttura impedisce l'accesso diretto al database dalla zona esposta su Internet. Solo l'applicazione

server può comunicare con il database tramite connessioni controllate, limitando l'impatto di eventuali compromissioni del front-end.

2) Impatto sul business di un attacco DDoS

Si ipotizza un attacco DDoS che renda la piattaforma non raggiungibile per 10 minuti.

Considerando una media di 1.500 € di transazioni al minuto:

$1.500 \text{ €} \times 10 \text{ minuti} = \mathbf{15.000 \text{ € di perdita diretta.}}$

Questo valore rappresenta solo il danno immediato.

A livello reale, si devono considerare:

- perdita di fiducia degli utenti,
- potenziale abbandono del sito,
- danno reputazionale,
- aumento richieste al supporto.

Un e-commerce vive di disponibilità: ogni minuto di fermo ha un impatto concreto.

2.1 Misure preventive

Per ridurre il rischio di DDoS si propone:

- utilizzo di un servizio anti-DDoS integrato in CDN o WAF gestito,
- rate limiting sugli endpoint più sensibili,
- monitoraggio continuo del traffico per rilevare anomalie.

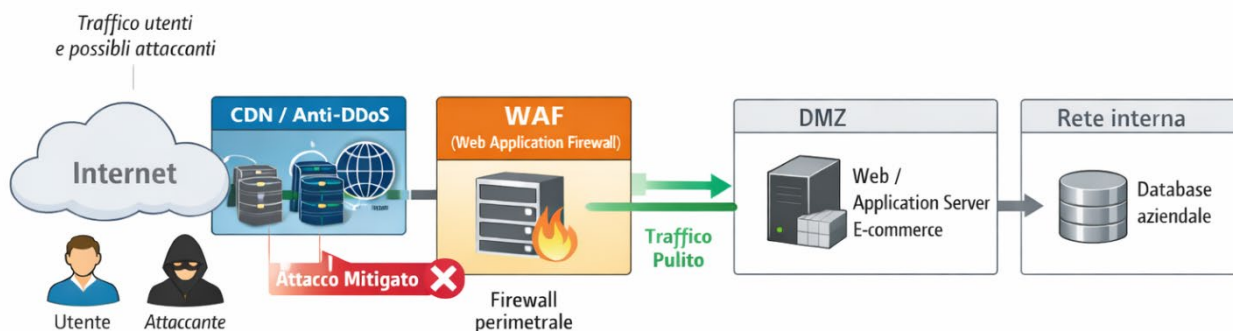


Figura 3 – Infrastruttura con CDN / Anti-DDoS posizionato davanti al WAF.

L'inserimento di un servizio CDN / Anti-DDoS gestito permette di mitigare attacchi volumetrici prima che il traffico raggiunga il WAF e la DMZ.

Figura 3 – Inserimento di un servizio CDN / Anti-DDoS a protezione dell'infrastruttura e-commerce. Il traffico proveniente da Internet viene filtrato e stabilizzato dal servizio CDN/Anti-DDoS prima di raggiungere il Web Application Firewall e la DMZ. Questa architettura consente di mitigare attacchi volumetrici e tentativi di saturazione del servizio, garantendo maggiore continuità operativa e disponibilità della piattaforma.

3) Response: infezione malware nella DMZ

Scenario: l'applicazione web viene infettata da malware.

La priorità è impedire la propagazione nella rete interna, non rimuovere immediatamente l'accesso dell'attaccante.

Questo significa adottare una strategia di containment.

3.1 Contenimento

Le azioni principali sono:

- bloccare il traffico DMZ → LAN tramite regole firewall,
- mantenere l'host compromesso isolato logicamente,
- raccogliere log e informazioni per analisi successiva.

In questo scenario si accetta un rischio controllato verso l'esterno, ma si protegge ciò che è più critico: la rete interna e i sistemi aziendali.

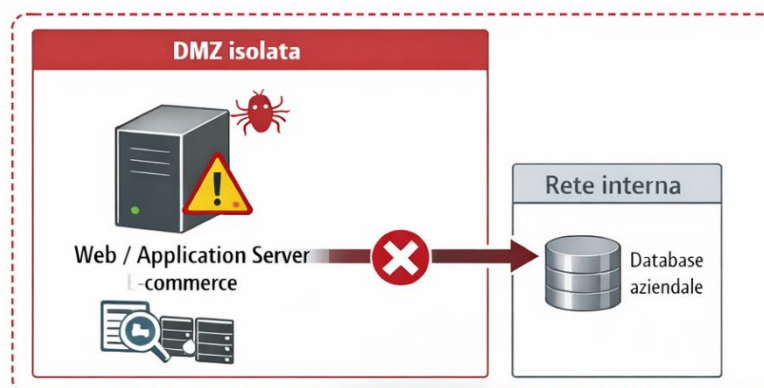


Figura 4 – Isolamento della DMZ per prevenire la propagazione di malware verso la rete interna.

In caso di compromissione del server esposto, la DMZ viene isolata dalla rete interna con regole firewall per bloccare il traffico, limitando la propagazione del malware e proteggendo i sistemi aziendali.

Figura 4 – Isolamento della DMZ in caso di compromissione del server esposto. In presenza di un'infezione malware, il traffico tra DMZ e rete interna viene bloccato tramite regole firewall dedicate. Questa misura di containment impedisce il movimento laterale verso i sistemi aziendali critici, preservando l'integrità della rete interna pur mantenendo operativa la zona esposta.

4) Soluzione completa integrata

Unendo prevenzione e response, l'architettura risultante prevede:

- protezione front-end con WAF e anti-DDoS,
- segmentazione rigorosa tra DMZ e LAN,
- accesso al database solo dall'application server,
- logging centralizzato,
- possibilità di isolamento rapido in caso di compromissione.

Questa architettura riduce sia la probabilità di successo di un attacco, sia l'impatto nel caso in cui avvenga.

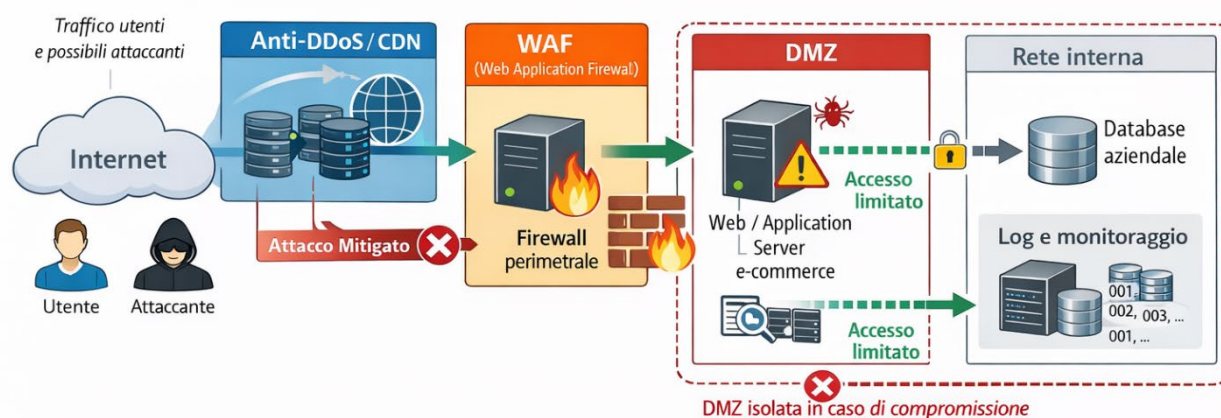


Figura 5 – Architettura finale integrata per un'e-commerce sicuro e segmentato

L'architettura completa include protezione Anti-DDoS/CDN per il filtraggio del traffico, WAF per il filtraggio delle richieste dannose, segmentazione della rete con DMZ isolata e logging continuo per il monitoraggio. Questi livelli di sicurezza garantiscono un'elevata Disponibilità e protezione dei dati aziendali.

Figura 5 – Architettura di sicurezza finale integrata per la piattaforma e-commerce. L'infrastruttura combina protezione Anti-DDoS/CDN, Web Application Firewall e segmentazione di rete per ridurre la superficie d'attacco e garantire la continuità operativa. L'accesso ai sistemi interni è limitato ai soli servizi necessari e tutte le attività vengono registrate tramite sistemi di logging e monitoraggio, consentendo una maggiore capacità di rilevamento e risposta agli incidenti.

5) Modifica più aggressiva dell'infrastruttura (Budget 30–40k €)

Con un budget limitato ma significativo, la strategia deve concentrarsi su interventi ad alto impatto.

5.1 Investimenti prioritari

1. WAF e protezione anti-DDoS gestita
2. Accesso amministrativo tramite VPN con autenticazione multi-fattore
3. Segmentazione firewall con principio deny by default
4. Logging centralizzato (anche soluzione leggera ma strutturata)
5. Eventuale penetration test applicativo annuale

Queste misure permettono di:

- ridurre la superficie d'attacco,
- aumentare la resilienza,

- migliorare la capacità di rilevamento,
- dimostrare maturità organizzativa.

5.2 Stima e allocazione del budget di sicurezza

Per rendere sostenibili le modifiche proposte è necessario distribuire il budget disponibile (30–40 mila euro) su soluzioni che garantiscano il miglior rapporto tra costo e riduzione del rischio.

L'obiettivo non è implementare un'infrastruttura enterprise complessa, ma introdurre controlli concreti e realistici che migliorino significativamente la postura di sicurezza.

Protezione WAF e Anti-DDoS gestita

Una parte rilevante del budget dovrebbe essere destinata a un servizio gestito di Web Application Firewall e protezione Anti-DDoS, integrato possibilmente in una soluzione CDN.

Costo stimato annuale: **8.000 – 12.000 €**

Questo investimento consente di:

- mitigare attacchi applicativi (SQLi, XSS),
- proteggere da traffico volumetrico,
- aumentare la disponibilità del servizio.

Accesso amministrativo sicuro (VPN + MFA)

Per ridurre il rischio di compromissione degli account amministrativi è fondamentale implementare accesso remoto sicuro tramite VPN con autenticazione multi-fattore.

Costo stimato implementazione e licenze: **4.000 – 6.000 €**

Benefici principali:

- eliminazione accessi diretti esposti su Internet
- maggiore controllo sugli accessi privilegiati
- tracciabilità delle attività amministrative

Segmentazione e hardening firewall

È necessario rafforzare la segmentazione tra DMZ e rete interna applicando il principio del minimo privilegio e configurando regole firewall più restrittive.

Costo stimato tra configurazione, eventuale upgrade firewall e manodopera:

6.000 – 8.000 €

Questo intervento riduce drasticamente il rischio di movimento laterale in caso di compromissione.

Sistema di logging e monitoraggio centralizzato

Un sistema di raccolta log centralizzato consente di monitorare eventi di sicurezza, tentativi di attacco e anomalie.

Costo stimato soluzione SIEM light o logging centralizzato:

5.000 – 7.000 €

Questo migliora la capacità di detection e supporta eventuali analisi forensi.

Penetration test applicativo periodico

Un penetration test annuale permette di individuare vulnerabilità non rilevate e verificare l'efficacia delle misure implementate.

Costo medio stimato: **5.000 – 7.000 €**

Questo rappresenta un investimento importante per mantenere un livello di sicurezza adeguato nel tempo.

5.3 Distribuzione complessiva del budget

Intervento	Costo stimato
WAF + Anti-DDoS	8k – 12k
VPN + MFA admin	4k – 6k
Segmentazione e firewall	6k – 8k
Logging centralizzato	5k – 7k
Penetration test	5k – 7k

Totale stimato: circa 30k – 40k €

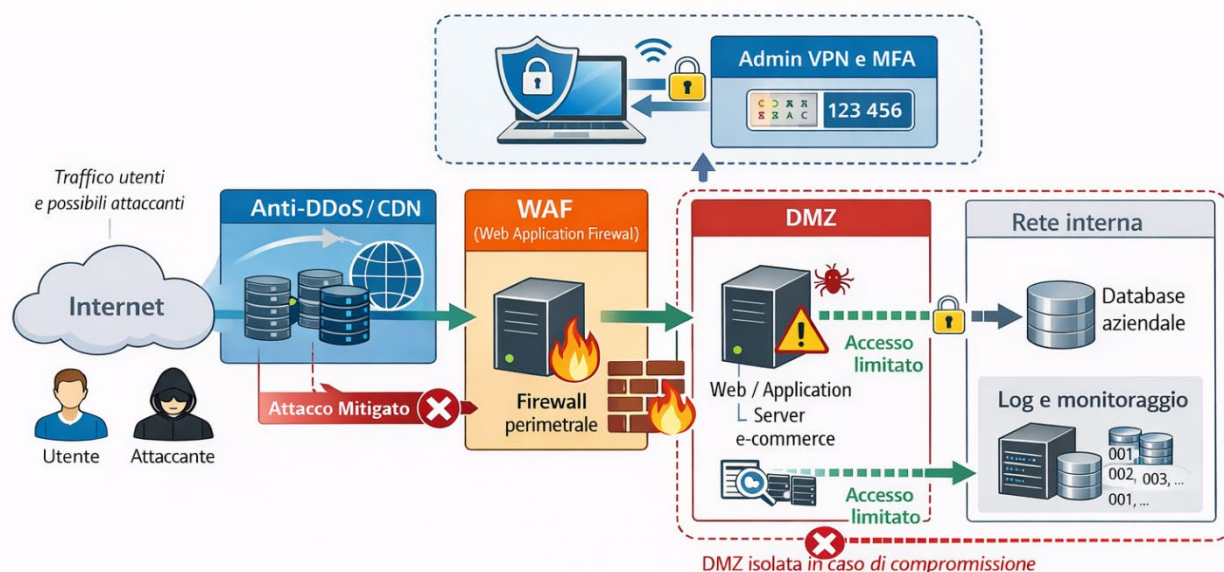


Figura 6 – Architettura di sicurezza avanzata per la gestione di e-commerce.

La combinazione di VPN e autenticazione a più fattori (MFA) per gli amministratori rafforza l'accesso agli ambienti critici, riducendo i rischi di compromissione dell'area di gestione. Questa architettura comprende protezione Anti-DDoS/CDN firewall applicativi, segmentazione della rete con DMZ isolata, e sistemi di logging continuo per garantire sicurezza e controllo d' avanzato dell'infrastruttura e-commerce.

Figura 6 – Architettura di sicurezza avanzata con accesso amministrativo protetto. L'infrastruttura integra protezione Anti-DDoS/CDN, Web Application Firewall, segmentazione della rete e sistemi di logging centralizzato. L'accesso amministrativo avviene esclusivamente tramite VPN con autenticazione multi-fattore (MFA), riducendo il rischio di compromissione degli ambienti critici e garantendo un controllo sicuro delle attività di gestione.

Conclusione

La sicurezza di una piattaforma e-commerce non può essere affidata a un singolo controllo tecnico. È necessario un approccio multilivello che integri protezione applicativa, segmentazione di rete, monitoraggio e capacità di contenimento.

Attraverso le misure proposte, l'infrastruttura risulta più resiliente agli attacchi comuni come SQL Injection, XSS e DDoS, e maggiormente in grado di limitare l'impatto di una compromissione malware.

Con un investimento mirato entro il budget disponibile è possibile ottenere un miglioramento significativo della postura di sicurezza, bilanciando protezione tecnica, sostenibilità economica e continuità operativa.